

PFS D6 - Auth Token Exchange

Clinical Data Sharing APIs (formerly DCAPI)

13 July, 2026

Table of Contents

1	Background	4
2	Decision	5
3	Option 1 - Exchange access token within APIM.....	6
3.1	APIM token exchange - overview diagram	6
3.2	APIM token exchange - step by step	6
3.3	APIM token exchange - sequence diagram	7
4	Option 2 - No token exchange within APIM	9

Status	COMPLETED
Stakeholders	Aubyn Crawford
Outcome	Exchange access token within APIM
Due date	 30 Nov 2022
Owner	Richard Booth
TRG	Include in SDO. No KAD required.

1 Background

As per [PFS D5 - Authentication](#)¹, GP Connect PFS APIs will be using NHS login credentials for end-to-end authentication.

In order to communicate with the NME's (Medicus in the first instance) APIs, requests originating from the Patient Facing Application (PFA) (NHS app in the first instance) need to include an access token issued from the NME's authorization (authZ) server. The authZ server is setup to respond to trusted origins only. In order to prevent abuse, misuse and reduce the burden on NMEs, it is not possible to have PFAs be setup as trusted origins. In order to present a single trusted origin to NMEs all requests must come via the NHS Digital APIM platform as this is a single, well known, trusted origin. As a consequence, all requests to the NME authZ and API servers must be proxied through APIM.

A token exchange mechanism is required within APIM that will be utilised for all requests from PFAs to facilitate communication with the NME in such a way as to provide the NME with the patient credentials.

1. <https://nhsd-confluence.digital.nhs.uk/display/DCA/PFS+D5+-+Authentication>

2 Decision

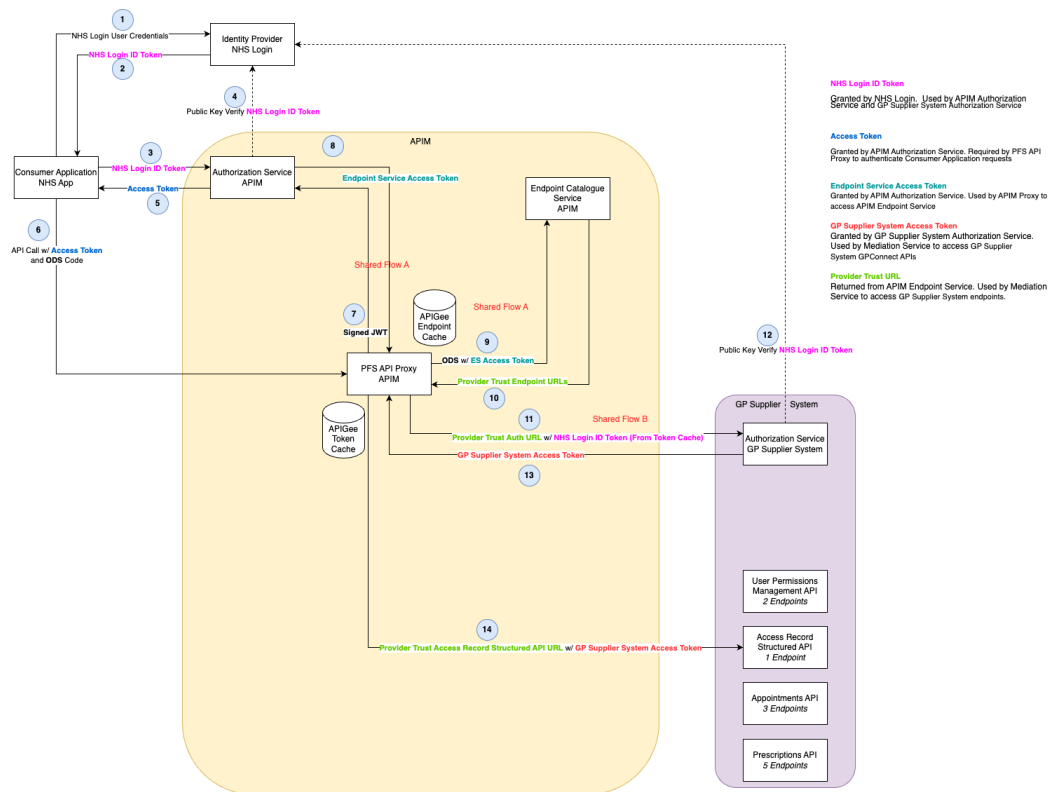
APIM will handle token exchange between the PFA and the NME, as described in **Option 1 - Exchange access token within APIM**.

3 Option 1 - Exchange access token within APIM

The access token issued to the PFA by NHS login will be presented to APIM and exchanged (after verification) for an access token which will subsequently be used by the patient application in requests to the APIM hosted PFS APIs. APIM will handle the requests to the NME's authZ server, handling caching and revalidation. As per [PFS D1 - Endpoint lookup and resolution](#)² APIM will also handle endpoint lookup.

How this would work can be seen in the diagram below along with the details of the steps:

3.1 APIM token exchange - overview diagram



3.2 APIM token exchange - step by step

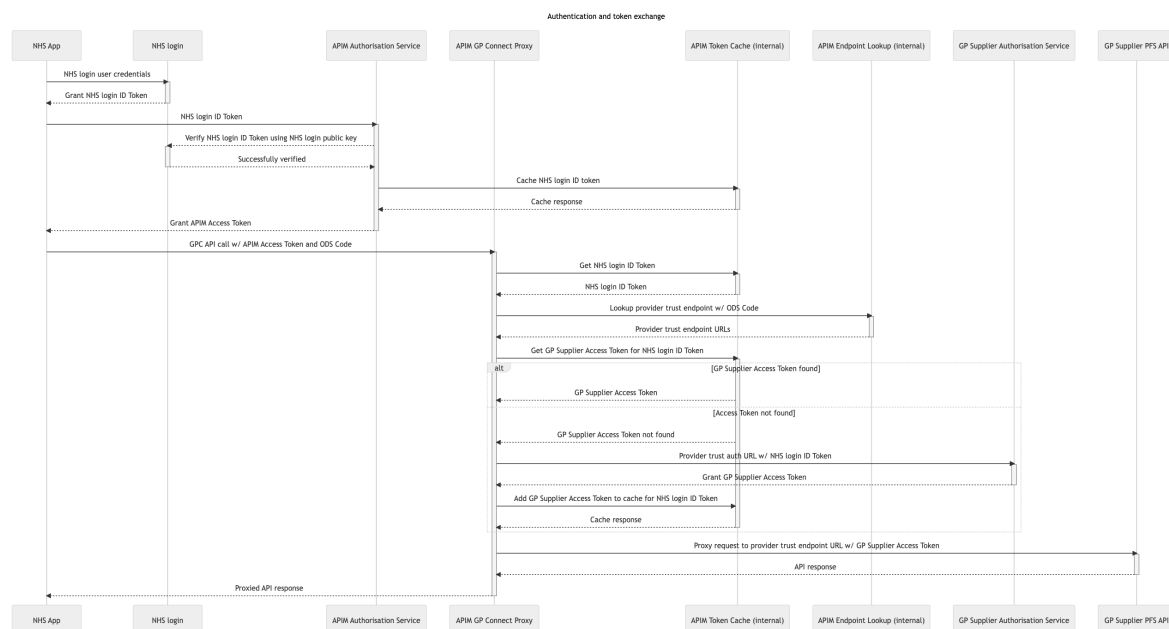
Prior to step 1 is when the patient would access the NHS app and initiate login via NHS login.

1. Patient enters their credentials

2. <https://nhsd-confluence.digital.nhs.uk/spaces/DCA/pages/520341345/PFS+D1+-+Endpoint+lookup+and+resolution>

2. NHS login returns control back to the NHS app along with the NHS login ID token
3. NHS app makes a request to the APIM authorization (authZ) service
4. APIM authZ service validates the NHS login ID token with NHS login
5. APIM access token returned to NHS app
6. NHS app makes request to (GP Connect) PFS API proxy within APIM. The request includes
 - a. the subject's NHS number (in URL)
 - b. the APIM access token (in header)
7. PFS API proxy validates APIM access token
8. Endpoint service access token returned
9. PFS API proxy makes request to endpoint catalogue service
10. Endpoint service returns details about GP System Supplier endpoints
11. PFS API proxy makes request to GP System Supplier's authZ service with NHS login ID token
12. GP System Supplier's authZ service validates NHS login ID token with NHS login
13. GP System Supplier authZ service returns a GP System Supplier access token
14. PFS API proxy makes request(s) to GP System Supplier API with the GP System Supplier access token

3.3 APIM token exchange - sequence diagram



Pros	Cons
• Provides central oversight and standards provided by NHS E • Provides visibility and metrics to NHS E • Suppliers can leverage the expertise of NHS E to aide trouble shooting and dealing with security • Low burden for consumers, no need to know which GP system is being called (as details are handled by NHS E) • Low burden for GP supplier (only a single origin to be trusted), no need to be open to the world or have a third party accreditation process • NHS E provides the first line of defence against abuse and misuse, reducing burden on supplier to a minimum • Follows existing, well known pattern of activity being performed centrally (same as endpoint lookup)	• NHS E must provide the resources and capability to perform activity

4 Option 2 - No token exchange within APIM

If token exchange wasn't performed within APIM every PFA would need to be onboarded with each NME in order to be checked and validated as a trusted origin. This is a high burden for both the PFA and the NME and increases the chances of mistakes or abuse of the system.

Pros	Cons
• Removes NHS E from having to do the work	• Increased burden for PFA as need to be validated by each NME • Increased burden for NME as each PFA must be validated • Increases development time • Potential for non-standard mechanisms to be introduced as no or little NHS D oversight